

CyberSOC Platform

API Gateway & Authentication Architecture

Secure Access Infrastructure Design
OAuth 2.0 | OIDC | SSO | mTLS | API Security

Document Type	Technical Architecture
Version	1.0.0
Date	2026-08-24
Component	Phase 1 - Critical Path Item #2

1. Introduction & Architecture Overview

The API Gateway and Authentication Architecture forms the security foundation for all CyberSOC Platform access, implementing zero-trust principles where every request carries verifiable credentials and authorization decisions occur at multiple enforcement points throughout the request lifecycle. This architecture addresses authentication (verifying identity), authorization (determining permitted actions), and accounting (logging all access for audit and compliance). The design supports diverse client types including browser-based admin interfaces, mobile applications, partner integrations via APIs, and service-to-service communication within the platform microservices architecture.

The architecture follows industry best practices for identity and access management while addressing specific requirements of cybersecurity platforms handling sensitive operational data. Multi-factor authentication is mandatory for all administrative access, session management implements appropriate timeouts and secure token handling, and the API gateway provides unified enforcement of rate limiting, request validation, and threat mitigation rules. Integration with enterprise identity providers through standard protocols (OAuth 2.0, OpenID Connect, SAML) enables seamless adoption within existing corporate identity management infrastructures.

Layer	Components	Protocol/Technology	Function
Identity Providers	Okta, Azure AD, Auth0, LDAP	OIDC, SAML 2.0, LDAP	External identity verification
Authentication Service	IDP Proxy, MFA Provider	OAuth 2.0, TOTP, FIDO2	Token issuance, credential validation
Session Management	Redis Cluster, JWT Store	JWT, Refresh Tokens	Session state, SSO coordination
API Gateway	Kong / Ambassador / AWS API GW	REST, gRPC, WebSocket	Request routing, policy enforcement
Authorization Engine	OPA / Casbin / Custom	Rego, ABAC policies	Permission evaluation
Service Mesh	Istio Linkerd	mTLS, SPIFFE	Service-to-service auth
Audit Layer	Event Pipeline	Async logging	Immutable access records

Table 1.1: Authentication Architecture Layers

2. Authentication Flows

The CyberSOC platform supports multiple authentication flows optimized for different client types and use cases. Browser-based applications utilize Authorization Code Flow with PKCE for enhanced security, preventing token interception during the OAuth dance. Server-side and machine-to-machine clients employ Client Credentials flow obtaining tokens directly without user interaction. Mobile applications may use Authorization Code Flow with PKCE or device authorization grant depending on device capabilities. All flows produce JWT access tokens containing standardized claims (sub, iss, exp, aud, scope) plus CyberSOC-specific claims encoding role, tenant context, and feature entitlements.

2.1 Browser Authentication (Authorization Code + PKCE)

Step	Action	Details	Security Measures
1	Initiate Login	Redirect to IDP with code_challenge	State parameter, nonce
2	User Authenticates	IDP handles credentials + MFA	IDP-specific (TOTP, WebAuthn)
3	Authorization Grant	IDP redirects with authorization code	Short-lived code (60s), HTTPS only
4	Token Exchange	Backend exchanges code for tokens	PKCE verification, client auth
5	Session Established	Access + refresh tokens stored securely	HttpOnly, Secure, SameSite cookies
6	API Access	Requests include Bearer token	Token validation per request

Table 2.1: Browser Authentication Flow

2.2 Service-to-Service Authentication (mTLS)

Internal microservices authenticate using mutual TLS (mTLS) where both client and server present certificates verified against a common trust anchor. The service mesh (Istio or Linkerd) manages certificate lifecycle including automatic rotation, eliminating manual key management overhead. Each service receives a SPIFFE-verifiable identity document encoding service name, namespace, and trust domain in X.509 certificate extensions. This identity propagates upstream enabling end-to-end attribution of requests to originating service without additional authentication headers that could be spoofed.

Aspect	Implementation	Configuration	Rotation Policy
CA Hierarchy	Istio Citadel or custom PKI	Root CA → Intermediate → Leaf	Intermediate: 30 days, Root: 1 year
Certificate Format	X.509 v3 with SPIFFE SANs	URI: spiffe://cybersoc/ns/svc/name	Leaf: 24 hours automatic
Trust Domain	cybersoc.platform.internal	Mesh-wide shared trust	Manual rotation required
Key Length	ECDSA P-256 or RSA 2048+	Configurable per workload	On rotation event
Revocation	OCSP stapling or CRL distribution	Short cert lifetime reduces need	Immediate on compromise

Table 2.2: mTLS Configuration Details

3. API Gateway Configuration

The API Gateway serves as the unified entry point for all external traffic to CyberSOC platform services, implementing cross-cutting concerns including authentication verification, rate limiting, request routing, response caching, and request/response transformation. Gateway configuration defines routes to backend services along with associated plugins enforcing policies. The recommended implementation uses Kong (open-source or enterprise) deployed within the Kubernetes cluster with horizontal scaling for high availability. Alternative options include Ambassador (edge-focused), AWS API Gateway (managed), or Traefik (cloud-native simplicity).

3.1 Route Configuration

Path Prefix	Backend Service	Authentication	Rate Limit	Notes
/api/v1/auth/*	auth-service	None (login endpoint)	100/min	Public endpoints only
/api/v1/admin/*	admin-api	JWT + RBAC check	50/min	Admin operations
/api/v1/siem/*	siem-engine	JWT validated	500/min	Core SIEM functions
/api/v1/soar/*	soar-engine	JWT + action scope	200/min	Automation execution
/api/v1/ti/*	threat-intel	JWT validated	300/min	Threat data access
/api/v1/ai/*	ai-copilot	JWT + AI license	100/min	AI features gated
/api/v1/mssp/*	mssp-service	JWT + tenant admin	100/min	Multi-tenant ops
/api/v1/integrations/*	integration-gw	JWT + integration secret	200/min	Third-party proxy
/api/v1/reports/*	report-service	JWT validated	50/min	Report generation

Table 3.1: API Route Configuration

3.2 Rate Limiting Policies

Tier	Global Limit	Per-User Limit	Burst Allowance	Throttling Response
Anonymous	100 req/min	N/A	20	429 Retry-After header
Authenticated User	500 req/min	200 req/min	50	429 + quota headers
Admin User	300 req/min	300 req/min	30	429 + warning email
Service Account	2000 req/min	N/A	200	429 + circuit breaker
API Key (Basic)	1000 req/min	Per key limit	100	429 + usage dashboard
Partner Integration	Custom SLA	Per contract	Per contract	429 + escalation contact

Table 3.2: Rate Limiting Tiers

4. Multi-Factor Authentication (MFA)

Multi-factor authentication is mandatory for all CyberSOC administrative access and strongly recommended for analyst accounts. The MFA implementation supports multiple factor types accommodating different security requirements and user preferences: Time-based One-Time Passwords (TOTP) via authenticator applications, WebAuthn/FIDO2 hardware keys providing phishing-resistant authentication, SMS/Voice delivery for accessibility scenarios, and backup codes for recovery when primary factors are unavailable. Administrators can enforce MFA policies at organizational level, requiring specific factors for certain roles or sensitivity levels.

Method	Security Level	Setup UX	Recovery Options	Recommended For
TOTP (Authenticator App)	High	QR Code scan	Backup codes	All users (default)
WebAuthn (Hardware Key)	Very High	USB/NFC tap	Another MFA method	Security-sensitive roles
SMS (Text Message)	Medium	Phone number entry	Voice call fallback	Accessibility backup
Email OTP	Low-Medium	Verified email	Alternative MFA	Not recommended alone
Push Notification	High	App approval	OTP fallback	Mobile-first orgs
Biometric (Device)	High	Device enrollment	PIN/password fallback	Mobile apps

Table 4.1: MFA Methods Comparison

4.2 MFA Policy Configuration

Policy Setting	Options	Default	Enforcement
MFA Required For	None/Admins/All Users/Roles	Admins only	Login gate check
Allowed Methods	Method whitelist selection	All available	Setup time filtering
Remember Device	Days (0/7/14/30)	7 days	Cookie-based bypass
Grace Period	Days for enrollment	3 days	One-time skip allowed
Step-up Auth	Sensitive actions trigger re-auth	Enabled	Action-level policy
Location-Based	Require MFA for new locations	Disabled	IP geolocation check

Table 4.2: MFA Policy Settings

5. Session Management

Session management governs the lifecycle of authenticated sessions from creation through expiration and revocation, balancing security (preventing unauthorized access via stale sessions) with usability (avoiding frequent re-authentication that disrupts workflow). The implementation uses short-lived JWT access tokens (15-minute default) combined with longer-lived refresh tokens (7-day default, revocable) stored in HTTP-only secure cookies for browser clients or secure storage for programmatic clients. Session state maintained server-side in Redis enables immediate revocation on security events (password change, admin deactivation, suspicious activity detection) without waiting for natural token expiration.

Parameter	Access Token	Refresh Token	ID Token	Session Cookie
Format	JWT (JWS)	Opaque (stored)	JWT (JWS)	Session ID reference
Lifetime	15 minutes	7 days	15 minutes	Configurable (default 8h)
Storage	Client memory	Redis cluster	Client memory	HttpOnly Secure cookie
Revocation	Wait expiry	Immediate (delete)	Wait expiry	Immediate (delete)
Rotation	N/A	Per-use (sliding)	N/A	Activity-based refresh
Claims	scope, roles, tenant	token_type, jti	profile, email	csrf_token, created_at

Table 5.1: Token and Session Configuration

5.1 Concurrent Session Limits

To prevent credential sharing and detect potential account compromise, the platform enforces configurable limits on concurrent active sessions per user. When a new login would exceed the limit, administrators choose between denying the new login (requiring logout of an existing session first) or terminating the oldest/stalest session automatically. Session lists visible to users show active devices with last activity timestamp and ability to remotely terminate suspicious sessions. High-assurance configurations for privileged accounts may enforce single-session-only mode ensuring exclusive access that must be explicitly released before another device can authenticate.

6. Security Headers & Threat Protection

The API Gateway and application layer implement defense-in-depth through multiple security mechanisms protecting against common web vulnerabilities and attack vectors. HTTP security headers instruct browsers on appropriate content handling restrictions. Input validation and output encoding prevent injection attacks. Request size limits and content-type restrictions mitigate denial-of-service vectors. The Web Application Firewall (WAF) layer provides virtual patching for known CVEs before underlying services can be updated, buying critical response time during security incident remediation.

Header	Value	Purpose	Protection Against
Strict-Transport-Security	max-age=31536000; includeSubDomains	Force HTTPS	SSL stripping
Content-Security-Policy	default-src 'self'; script-src 'self'	Resource loading control	XSS injection
X-Content-Type-Options	nosniff	Prevent MIME sniffing	Drive-by downloads
X-Frame-Options	DENY	Prevent iframe embedding	Clickjacking
X-XSS-Protection	1; mode=block	Browser XSS filter	Reflected XSS
Referrer-Policy	strict-origin-when-cross-origin	Control referrer leakage	Privacy exposure
Permissions-Policy	camera=(), microphone=()	Feature restriction	Unauthorized access
Cache-Control	no-store for auth, public for static	Response caching	Sensitive data caching

Table 6.1: Security Headers Configuration

6.1 WAF Rules Configuration

Rule Category	Protected Vulnerabilities	Action	Severity Threshold
SQL Injection	SQLi in parameters, body, headers	Block + Alert	Any detection
Cross-Site Scripting	Reflected, stored XSS vectors	Sanitize + Block	High confidence
Remote Code Execution	Command injection, path traversal	Block immediately	Any detection
SSRF Prevention	Internal IP/url access attempts	Block + Validate	Private ranges
Authentication Abuse	Brute force, credential stuffing	Rate limit + CAPTCHA	>5 failures/min
Bot Mitigation	Scrapers, automated abuse	Challenge/Block	Behavioral score <50
File Upload Safety	Malicious file type uploads	Validate + Quarantine	Executable types

Table 6.2: WAF Rule Categories

7. Identity Provider Integration

CyberSOC integrates with enterprise identity providers through standard protocols, enabling organizations to leverage existing identity management investments and user provisioning workflows. Primary integration uses OpenID Connect (OIDC) for modern identity providers (Okta, Azure AD, Auth0, Google Workspace) providing rich user profile data and standardized authentication flows. Legacy SAML 2.0 support accommodates enterprise environments where SAML remains the standard for federated authentication. LDAP/Active Directory integration supports hybrid deployments requiring direct directory authentication without cloud identity provider dependency.

IDP Type	Protocol	Use Case	Mapping Complexity	MFA Handling
Okta	OIDC	Enterprise SaaS standard	Low (standard claims)	Delegated to Okta
Azure AD	OIDC/SAML	Microsoft ecosystem	Medium (Graph API)	Azure AD Conditional Access
Google Workspace	OIDC	Google-centric orgs	Low (standard claims)	Google 2SV
Auth0	OIDC	Customizable IDP needs	Medium (rules engine)	Auth0 MFA factors
Active Directory	LDAP/SAML	On-prem legacy	High (schema mapping)	AD CS / RSA SecurID
Custom OIDC	OIDC	Specialized providers	Variable	Provider-dependent

Table 7.1: Identity Provider Integration Matrix

7.1 SCIM Provisioning Integration

Automated user provisioning through SCIM (System for Cross-domain Identity Management) ensures CyberSOC user directories stay synchronized with authoritative identity sources (typically the corporate HR system or Active Directory). When employees join, leave, or change roles, those changes propagate automatically to CyberSOC without manual administrator intervention. The SCIM integration supports bidirectional sync: pushing CyberSOC-specific attributes back to the identity provider where custom schema extension is supported, and importing changes from the identity provider on scheduled intervals or via webhook notifications.

Operation	Direction	Trigger	Attributes Synced
User Create	IDP -> CyberSOC	HR hire event / AD create	name, email, department, manager
User Update	Bidirectional	Attribute change detected	name, email, phone, title
User Deactivate	IDP -> CyberSOC	Termination / AD disable	status, deactivation date
Group Sync	IDP -> CyberSOC	Group membership change	groups, role mappings
License Assignment	CyberSOC -> IDP	Entitlement change	custom cybersoc:license attribute

Table 7.2: SCIM Provisioning Operations

8. Implementation Checklist

This checklist provides a comprehensive task list for implementing the API Gateway and Authentication Architecture. Items are organized by functional area with dependencies noted where applicable. Each item should be verified complete with evidence (configuration screenshot, test result, documentation reference) before marking done. The checklist supports both initial implementation and subsequent audits verifying continued compliance with security requirements.

#	Task	Area	Priority	Verification
1	Deploy API Gateway (Kong/Ambassador)	Infrastructure	Critical	Health endpoint responding
2	Configure TLS termination with valid cert	Infrastructure	Critical	A+ SSL Labs score
3	Implement OIDC client registration	Auth	Critical	Token issuance working
4	Configure MFA providers (TOTP, WebAuthn)	Auth	Critical	Enrollment flow tested
5	Set up Redis cluster for sessions	Infrastructure	High	Failover tested
6	Implement JWT validation middleware	Auth	Critical	Invalid tokens rejected
7	Configure rate limiting by tier	Gateway	High	429 responses verified
8	Set up mTLS for service mesh	Infrastructure	High	Inter-service calls authenticated
9	Implement OPA policy decision	AuthZ	High	Deny policies enforced
10	Configure security headers	Security	Medium	SecurityHeaders.com pass
11	Set up WAF rule sets	Security	High	OWASP Top 10 covered
12	Implement SCIM endpoint	Integration	Medium	Provisioning sync working
13	Configure audit logging pipeline	Compliance	High	All auth events captured
14	Document emergency break-glass procedure	Operations	Medium	Runbook written
15	Load test authentication endpoints	Performance	High	<100ms p99 at scale

Table 8.1: Implementation Checklist

This API Gateway and Authentication Architecture specification establishes the security foundation upon which all other CyberSOC platform components depend. Proper implementation of these capabilities is prerequisite to production deployment, as weaknesses in authentication or API security undermine the protections implemented throughout the rest of the platform. Regular security review of this layer, including penetration testing focused on authentication bypass and API abuse vectors, should occur at minimum annually and following any significant configuration changes.